Picsart AI Influencer Studio — Master QA Report

Date: March 30, 2026 **Target:** https://picsart.com/ai-influencer-studio/ **QA Team:** Atlas (Lead), Scout (Functional), Rover (Bug Hunt), Sentinel (Security) **Scope:** Logged-out state — functional, security, edge cases, URL manipulation **Product:** Picsart Persona — 3-step wizard (Vibe Check → Shape → Evolve)

Executive Summary

Three QA agents tested the Picsart AI Influencer Studio in parallel, covering functional verification, bug hunting, and security assessment. Combined findings:

Metric	Count
Total Unique Findings	**36**
🔴 Critical	2
🔴 High	5
🟡 Medium	14
🟢 Low	6
ℹ️ Info	5
✅ Confirmed Defenses	4

Top 5 Issues by Business Impact

1. **SEC-001 + SEC-003** — picsart.com is missing ALL security headers AND CDN has dangerous CORS wildcard+credentials. Combined, this means zero XSS mitigation + potential cross-origin data access.
2. **BUG-ROVER-005** — Invalid `personaStep=99` silently redirects to ai-playground (different product). Broken deep links and confused users.
3. **BUG-SCOUT-002** — `?personaVibe=streetwear` fails silently (real ID is `streetwear_hypebeast`). Marketing links break.
4. **BUG-ROVER-001** — `authState: "authorized"` persists in localStorage after logout. Stale auth state causes inconsistent behavior.
5. **SEC-002** — Auth cookies (`authState` , `REFRESH_TOKEN`) have no HttpOnly/Secure/SameSite. XSS = full account takeover.

Consolidated Findings

🔴 Critical (2)

ID	Title	Agent	OWASP
SEC-001	Missing ALL security headers on picsart.com (no CSP, HSTS, X-Frame-Options, Referrer-Policy, Permissions-Policy)	Sentinel	A05:2021
SEC-003	CDN subdomains (pastatic.picsart.com, cdn140.picsart.com) return `Access-Control-Allow-Origin: *` + `Access-Control-Allow-Credentials: true`	Sentinel	A01:2021

🔴 High (5)

ID	Title	Agent
SEC-002	Auth cookies (`authState`, `REFRESH_TOKEN`) missing HttpOnly/Secure/SameSite	Sentinel

BUG-ROVER-001	`authState: "authorized"` persists in localStorage without valid session	Rover
BUG-ROVER-005	`personaStep=99` silently redirects to ai-playground (different product)	Rover
BUG-ROVER-006	`personaStep=-1` silently adopts previous session's state (state pollution)	Rover
BUG-SCOUT-002	`?personaVibe=streetwear` silently fails — real ID is `streetwear_hypebeast`	Scout

🟡 Medium (14)

ID	Title	Agent
SEC-004	User IDs stored in localStorage (accessible to all scripts)	Sentinel
SEC-005	Auth cookie names leaked on unauthenticated page load	Sentinel
SEC-007	No clickjacking protection (no X-Frame-Options or frame-ancestors)	Sentinel
SEC-008	Tracking operates in opt-out mode (GDPR risk for EU users)	Sentinel
BUG-ROVER-004	Page title renders as `[object Object]` on 3rd consecutive reload (React hydration bug)	Rover
BUG-ROVER-007	Invalid `personaVibe=nonexistent` silently dropped without feedback	Rover
BUG-ROVER-008	`pathname` parameter injected into URL on every navigation (URL pollution)	Rover
BUG-ROVER-010	Primary miniapp iframe has no `sandbox` attribute	Rover
BUG-ROVER-011	HubSpot chat iframe has no `sandbox` attribute	Rover
BUG-ROVER-012	Page marked `noindex, nofollow` — missing description, OG tags, canonical, viewport meta	Rover
BUG-SCOUT-001	URL parameter pollution — `pathname=` appended to every URL	Scout
BUG-SCOUT-003	Page title is just "Picsart" — no descriptive title for any step	Scout
BUG-SCOUT-004	Generate button disabled on Step 3 with zero explanation for logged-out users	Scout
SEC-006	`X-Powered-By: Next.js` technology disclosure	Sentinel

🟢 Low (6)

ID	Title	Agent
SEC-009	Full micro-frontend architecture disclosed via public remotes-manifest.json	Sentinel
BUG-ROVER-002	`visitCount` key added to localStorage on return navigation	Rover
BUG-ROVER-014	`clipboard-read` in iframe allow policy is overly broad	Rover
BUG-ROVER-015	Missing viewport meta tag affects mobile rendering	Rover
BUG-SCOUT-005	Credit badge shows "98.5k" to logged-out users — confusing context	Scout
SEC-010	miniapps-webapps.picsart.com returns HTTP 500 at root	Sentinel

ℹ️ Info (5)

ID	Title	Agent
BUG-ROVER-003	Drive save entries expose user UUID in localStorage	Rover

BUG-ROVER-013	61 tracking cookies set on first visit	Rover
NOTE-SCOUT-001	Character Inspirations gallery not visible in logged-out state	Scout
NOTE-SCOUT-002	Fruit Friends vibe has unique UI (no gender/age — avatar mode)	Scout
NOTE-SCOUT-003	Poetcore display name vs ID mismatch (`poetcore_scholar`)	Scout

✅ Confirmed Defenses (4)

ID	Title	Agent
BUG-ROVER-009	Cloudflare WAF blocks XSS payloads in URL params (403)	Rover
BUG-ROVER-009b	Cloudflare WAF blocks SQL injection patterns (403)	Rover
SEC-API-OK	api.picsart.com CORS correctly restricted to picsart.com	Sentinel
SEC-MINIAPP-OK	miniapps-webapps.picsart.com has proper COEP/COOP/CORP headers	Sentinel

---

Functional Verification Matrix

Feature	Status	Notes
Studio loads without login	✅ PASS	Redirects to Step 1
All 23 vibe categories present	✅ PASS	All verified with IDs
Vibe selection enables Next	✅ PASS	
Step 2 customization loads (Y2K)	✅ PASS	71 thumbnails, 12 sections
Step 2 customization loads (Streetwear)	✅ PASS	Via `streetwear_hypebeast` only
Step 2 customization loads (Cottagecore)	✅ PASS	60 thumbnails
Step 2 customization loads (Cyberpunk Edge)	✅ PASS	65 thumbnails
Step 2 customization loads (Fruit Friends)	✅ PASS	Unique UI, 24 options
Gender options (5 inclusive)	✅ PASS	Female, Male, Trans Man, Trans Woman, Non-binary
Ethnicity options (10 inclusive)	✅ PASS	All present
Skin features (8)	✅ PASS	Including Vitiligo, Albinism, Burns
Surprise Me button	✅ PASS	All character vibes
Photo upload option	✅ PASS	Character vibes only
Progress indicator (3 steps)	✅ PASS	Correct state machine
Back button (Steps 2, 3)	✅ PASS	
Step 3 (Evolve) accessible	✅ PASS	Via URL params
Generate button visible	⚠️ PARTIAL	Visible but disabled, no explanation
Credit info icon	✅ PASS	`credit-info` element present
Step bypass via URL	❌ BUG	Step 3 accessible without Step 2

URL stays clean	❌ BUG	pathname= pollution everywhere
Page title descriptive	❌ BUG	"Picsart" on all steps
Vibe ID URL mapping	❌ BUG	`streetwear` fails silently

Vibe ID Reference (for deep linking & testing)

Display Name	URL Param (personaVibe)	Type
Fruit Friends	fruit_friends	Avatar/Mascot
Pets	pets	Avatar/Mascot
Y2K	y2k	Character
Creatures	creatures	Avatar/Mascot
Coquette	coquette	Character
Luxury Elite	luxury_elite	Character
Wellness Guru	wellness_guru	Character
Old Money	old_money	Character
Career Pro	career_professional	Character
Streetwear	**streetwear_hypebeast** ⚠️	Character
Soft Goth	soft_goth	Character
Cottagecore	cottagecore	Character
Ethereal Angel	ethereal_angel	Character
Cyberpunk Edge	cyberpunk_edge	Character
Dark Fantasy	dark_fantasy	Character
Cute & Kawaii	cute_kawaii	Character
Fairy Fantasy	fairy_fantasy	Character
Effortlessly Cool	effortlessly_cool	Character
Retro Revival	retro_revival	Character
Fun & Playful	fun_playful	Character
Grunge Alt	grunge_alt	Character
Futuristic	futuristic	Character
Poetcore	**poetcore_scholar**	Character

Security Posture Summary

Area	Grade	Key Issues

HTTP Headers	🔴 F	Zero security headers on main domain
CORS	🔴 D	CDN wildcard+credentials; API is OK
Cookies	🔴 D	Auth cookies have no security attributes
Client Storage	🟡 C	PII-adjacent data, stale auth state
Iframe Security	🟡 C	No sandbox, excessive permissions
WAF/Input Validation	✅ A	Cloudflare blocks XSS/SQLi
Miniapp Headers	✅ A	Proper COEP/COOP/CORP
API CORS	✅ A	Correctly restricted

Prioritized Action Plan

🔴 P0 — Fix This Week

#	Action	Fixes	Effort
1	Add security headers to picsart.com (CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy)	SEC-001, SEC-007	1 day
2	Fix CORS on CDN subdomains — remove wildcard+credentials	SEC-003	1 day
3	Add HttpOnly, Secure, SameSite to auth cookies	SEC-002	1 day
4	Fix `personaStep` validation — clamp to 1-3, don't redirect to ai-playground	BUG-ROVER-005, BUG-ROVER-006	2 hours
5	Add URL alias: `streetwear` → `streetwear_hypebeast`	BUG-SCOUT-002	1 hour

🟡 P1 — Fix This Sprint

#	Action	Fixes	Effort
6	Clear `authState` from localStorage on logout	BUG-ROVER-001	2 hours
7	Stop injecting `pathname=` into URL	BUG-ROVER-008, BUG-SCOUT-001	4 hours
8	Fix React hydration bug causing `[object Object]` title	BUG-ROVER-004	4 hours
9	Add sandbox to miniapp iframe	BUG-ROVER-010	2 hours
10	Add "Sign in to Generate" CTA for logged-out users	BUG-SCOUT-004	4 hours
11	Set descriptive page title per step	BUG-SCOUT-003, BUG-ROVER-012	2 hours
12	Switch tracking to opt-in for EU users	SEC-008	1 day

🟢 P2 — Backlog

#	Action	Fixes
13	Add viewport meta tag	BUG-ROVER-015
14	Add OG tags, meta description, canonical URL	BUG-ROVER-012

15	Remove `X-Powered-By: Next.js`	SEC-006
16	Remove `clipboard-read` from iframe allow policy	BUG-ROVER-014
17	Restrict remotes-manifest.json access	SEC-009
18	Clarify or hide credit badge for logged-out users	BUG-SCOUT-005

Not Tested (Requires Logged-In State)

The following areas were blocked by Picsart's login rate limiting and cross-origin iframe restrictions:

Area	Accounts Needed	Why Blocked
Persona creation flow	Pro, Ultra	Can't click Generate inside iframe
Persona persistence bug	Pro, Free, Ultra	Can't create then verify persistence
Video poster outfit change bug	Pro	Can't generate videos
Credit depletion UX	Free No Credits, Pro No Credits	Can't test at 0 credits
Drive full behavior	Drive Full account	Can't test save/export
Post-expiry access	Expired account	Can't verify feature degradation
Free→Pro upgrade transition	Free→Pro account	Can't test mid-session upgrade
Account isolation	Multiple accounts	Can't switch accounts
Feature gating comparison	All tiers	Can't compare tier differences

Recommendation: These tests should be run manually or with pre-authenticated Playwright sessions (using saved `storageState` files).

Testing Methodology

Tools Used

- Browser automation (Chrome 146 via CDP)
- curl for HTTP header/CORS analysis
- URL parameter manipulation for wizard navigation
- localStorage/cookie inspection via page.evaluate
- Screenshots for visual evidence

Approach

All testing performed in **logged-out state** to avoid Picsart's login rate limiting. URL parameters (`personaStep` , `personaVibe`) used to navigate wizard steps. Iframe content read via frame snapshots.

Coverage

- ✅ 23 vibe categories verified
- ✅ 5 vibes deep-tested (customization options counted)
- ✅ 3 wizard steps verified (progress, navigation, state)
- ✅ 12 URL manipulation scenarios tested
- ✅ Security headers on 5 domains checked
- ✅ CORS tested on 5 endpoints
- ✅ Cookie and localStorage audited

- ✅ Iframe attributes inspected
- ✅ Mobile (375px) and ultrawide (2560px) viewports tested
- ✅ XSS and SQLi WAF validation
- ❌ Logged-in flows (blocked by rate limiting)

Report compiled by Gvenik (Orchestrator) from Scout, Rover, and Sentinel reports Task ID: mnd6dbr3-tso1vj | Subtasks: mnd6dlpk-0aoi26, mnd6dlq4-mwy6mw, mnd6dlqp-dajpaq